

Case 3

Penetration Testing

Group 15

Al-Towhi, Khalil

Gautam, Ankit

Hasan, Mohammad Kamrul

Shareiyat, Ammar

To perform a penetration test of Radio Sweden's infrastructure, a step-by-step procedure has been followed based on NIST SP 800-115 Technical Guide.

Introduction

As information security consultants, we have decided to follow the NIST SP 800-115 document to perform the penetration testing and provide examples of security controls and security metrics.

According to the NIST guide document the penetration testing consists of four phases.

Phase 1: Planning

Phase 2: Discovery

Phase 3: Attack

Phase 4: Reporting

Phase 1: Planning

Scope:

All vulnerabilities in the system were identified in the attached table below. The table contains the type, name of the assets within Radio Sweden, and then the type of potential vulnerability to these assets. The responsible department for penetration testing is the IT department of Radio Sweden. Focusing on this stage is important in the success of the penetration test process because examining the system and the assets with vulnerability helps in achieving the penetration test.

Assets:

Infrastructure: Firewalls, Routers, Switches, Servers, Laptops,

Systems: Web Server, FTP, Backup servers, payroll system, Anti-malware software,

Active Directory server, VPN server,

Phase 2: Discovery

Below are some of the assets that we found could be potential to be attacked in the system

Type	Name	Vulnerability
Firewall	Cisco ASA 5500 firewall	Insider attack, missing security patches, configuration mistakes, lack of deep packet inspection, DDoS attack, failure to activate controls .CVE-2013-0149 - DoS Vulnerability
Routers	Cisco 8808 routers	Potential Security Risks Caused by the Openness of IP Networks, Existence of Insecure Access Channels, Challenge from Complexity of routers -CVE-2021-1244 - This could allow a local attacker to execute code during the boot.
Switches	HP Office Connect 1850 Gigabit switches	Mac Flooding, DHCP Spoofing, ARP Spoofing -CVE-2017-5786 - Integrity Impact vulnerability
Servers	Windows servers 2016, GNU/Linux Redhat servers, Solaris 11.1	DDoS, Cross-Site Request Forgery -CVE-2014-0397 Overflow -CVE-2021-21322 -CVE-2021-21321
Computers and OS	Windows 10 pro - 64 bit	-CVE-2020-16898- Remote code execution vulnerability -CVE-2020-16947- Outlook vulnerability -CVE-2020-1599- bypassing the app signature -CVE-2020-16937- .Net Framework disclosure vulnerability

Telephone & Emails	Targeted employee	Social engineering Ransomware vulnerability Phishing, SPAM
--------------------	-------------------	--

Phase 3: Attack

-Gaining access: By gathering the required information for penetration testing during the previous phase, we can fulfill attempts to access different targets. For instance, by sending phishing emails to the employees we as a tester are able to gain access to a certain target.

-Escalating privilege: If we get success to gain access, we can seek control of the whole system.

-System browsing: Discovery phase will be repeated to identify mechanisms such as some tools (Nmap) to gain access to additional systems.

-Install additional tools: By installing additional software such as backdoors, eavesdropping, and even worms or trojan tools, the tester can exploit the vulnerabilities to simulate attacks.

Phase 4: Reporting

This phase should be done simultaneously along with the previous phases.

Security control	Metrics	Purpose	source
Educating and training the employees and journalists	A number of employees or journalists who have completed the training.	Mitigate the threats that are caused by user's mistakes.	e-Learning software.
Email	Spam detected/filtered	Indicator of email pollution	Email content filtering software.
Updating software	Old Software versions	Identify all the software which needs to be updated	Using Software Center or company portal software through Windows
Patch management	Unapplied patches	Identifying the	Using software for

		required patches to cover the vulnerabilities	patch management
Vulnerability management	Number of vulnerabilities	Identify the level of responsiveness for fixing the vulnerabilities that affect critical assets.	Using vulnerability management software
Firewall and Network Parameter	Firewall Rule Changs, Sites with open wireless access points	Suggest level of security complexity	Firewall Management System
Antivirus	Spyware detected in journalist and employees files on their laptops and servers	Indicator of infection rate on laptops and servers	Server and desktop antispayware and antivirus software.
System Recovery	Mean Time to recovery time	Suggest how long it take to recover from an incident	Spreadsheets
Code security Metrics	Lines of code	Shows the aggregate size of a developed web application	Code analysis software
Monitor and evaluate internal controls	Review the critical systems for compliance	Ensure the compliance	Monitoring software and have evaluation sessions periodically.
Qualitative Process	Business Adjusted Risk	Identifying Business Impacted areas, severity and criticality of vulnerabilities	Security Assessments Spreadsheets

References:
NIST SP 800-115